

closure_evidence_20260923

BOB-212 closure evidence — 2026-09-23

Investigation already recorded on the tracked item (SCOPED AND MEASURED

2026-08-26 section) — recommendation (b), option (a) empirically
DISPROVEN

Full investigation, measurement, and recommendation already exist verbatim on the tracked item's own description (see docs/Fixed.md BOB-212 entry). Summary: narrowing the deny-all glob (option a) leaks a real credential file already in this tree (download-proxy/qbittorrent_creds.json) and was disproven, not merely disfavoured; option (b) — keep the globs unchanged, add a LOUD guard scoped to first-party source-extension files — leaks nothing (empty set) and was recommended.

RED test already existed, already tracked (this session's work is the

GREEN half)

tests/security/test_gitignore_swallow_is_loud.sh was already authored and committed (Aug 31) before this session. Independently confirmed genuinely RED at session start:

```
$ bash tests/security/test_gitignore_swallow_is_loud.sh
...
-- A2: does a swallow-guard exist and refuse loudly, naming rule +
file? --
```

```
..      no swallow-guard at /home/milosvasic/Projects/boba/
scripts/pre_build/check_gitignore_swallow.sh
RESULT: FAIL (exit 1) – the swallow is SILENT. B0B-212 acceptance
not met.
```

Fix

New scripts/pre_build/check_gitignore_swallow.sh implementing option (b) exactly: .gitignore's deny-all globs are left completely unchanged; the new script refuses (non-zero exit, naming both the file and the exact .gitignore:<line> blocking rule) any UNTRACKED, ignored file that is BOTH under a first-party source root (excludes submodules/, vendored/third- party trees, build output, caches, runtime-deployment-target directories) AND carries a recognised source-code extension (deliberately excludes every extension/shape this project treats as secret-bearing: .env, .pem, .key, .p12, .jks, *creds*.json, *_password*, cookies_*, etc.). Wired into scripts/pre_build_verification.sh as new invariant 56 (CM-GITIGNORE-SWALLOW-GUARD), with the file's total invariant count correctly bumped 55→56 throughout.

Independently verified this session (coordinator)

```
$ bash tests/security/test_gitignore_swallow_is_loud.sh
-- A2: does a swallow-guard exist and refuse loudly, naming rule +
file? --
[ok]      guard refused (exit 1) and named both the file and
the .gitignore rule
-- ACCEPTANCE (B0B-212): commits normally OR loud refusal – never
silence --
[ok]      a signal reaches the author
-- GOLDEN-FALSE (§11.4.201(1)/§11.4.10): real secrets MUST stay
ignored --
[ok]      all 15 secret-bearing shapes remain ignored
RESULT: PASS (exit 0) – the swallow is LOUD (or the file commits
normally).
```

```
$ bash tests/pre_build/test_check_gitignore_swallow.sh
-- case 1: golden-GOOD (swallowed first-party source file) -- PASS
-- case 2: golden-BAD / false-positive guard -- PASS
-- case 3: genuinely clean tree -- PASS
-- case 4: swallowed file under an excluded root -- PASS
-- case 5: fail-closed on unresolvable input (§11.4.252) -- PASS
(5a, 5b)
```

```
-- case 6: paired $1.1 mutation -- PASS (6a, 6b, 6c)
RESULT: PASS – all cases behaved as specified (0 failures).
```

Both re-run 3 consecutive times each; identical results every time.

Confirmed tests/security/test_gitignore_swallow_is_loud.sh and scripts/pre_build_verification.sh's PRE-EXISTING 55-invariant logic were untouched by the subagent (only the new invariant 56 block + the global 55→56 renumbering, done by the coordinator directly, were added).

First real-repo run immediately caught a genuine live instance

The very first run of invariant 56 against this real checkout (not a scratch/test tree) found TWO genuinely-swallowed first-party source files that had existed on disk since 2026-09-01 and were in daily functional use by pre_build_verification.sh invariant 53, yet were NEVER committed to git — filed and fixed as its own item, BOB-229 (see docs/qa/BOB-229/closure_evidence_20260923.md), and the strongest possible proof this guard genuinely works: it is not a synthetic exercise, it caught a real, live defect on its first real-world run.

Explicit honest-boundary note (per the item's own acceptance criteria)

scripts/pre_build_verification.sh wiring (invariant 56) IS now done — this closes the loop the original brief deliberately deferred. Criterion (4) — “frontend/e2e/credentials.spec.ts is made safe by rule rather than by the accident of already being tracked” — is satisfied going forward: the guard now runs as part of every scripts/commit-push-all.sh invocation (via pre_build_verification.sh stage 3), so a future delete-and-re-add of that file would now be caught BEFORE the commit lands, not merely be a theoretical protection.

git diff –stat (this item's own scope)

scripts/pre_build/check_gitignore_swallow.sh	new file, 222 lines
tests/pre_build/test_check_gitignore_swallow.sh	new file, 222 lines
scripts/pre_build_verification.sh	+41/-0 (new)

invariant 56 block) + 55->56 renumbering across 46 existing echo
labels